

CYBERSECURITY LAB REPORT

ATM Jackpotting:

Penetration-Test Findings & Quantitative Analysis

Red-Team Lab Exercise · Authorized Test Environment

Prepared by: Red Team Cohort 04

Course: Offensive Security & Embedded Systems

Report Date: 11 May 2026

Classification: Educational · Internal Use

1. Executive Summary

“Jackpotting” is a class of attack in which an adversary causes an automated teller machine (ATM) to dispense its entire cash inventory on demand, typically by combining physical access to the machine’s service compartment with malicious software, a rogue device, or abuse of vendor diagnostic protocols. The term entered mainstream security vocabulary after Barnaby Jack’s 2010 Black Hat demonstration, and the technique has since matured into a globally deployed criminal toolset — Ploutus, Cutlet Maker, FastCash, and several successor families remain in active circulation as of 2026.

This report documents the results of an authorized red-team lab exercise conducted against a surplus, vendor-decommissioned ATM simulator on an air-gapped network. The objective was twofold: (1) assess the unit’s resilience against five recognized jackpotting attack vectors, and (2) produce quantitative data — both internal trial measurements and externally sourced industry statistics — that can be used to communicate jackpotting risk to non-technical stakeholders.

Across 33 distinct findings, the team observed a strongly right-skewed CVSS distribution dominated by High and Critical severities, with a mean time-to-cash-dispense of approximately 21 minutes across all attack vectors. The most effective mitigations were full-disk encryption and application allowlisting; both reduced trial-level attack success rates by more than 60 percentage points.

2. Lab Environment & Methodology

All testing was performed under written authorization in an isolated, air-gapped laboratory. No production banking infrastructure was contacted at any point, no live cash cassettes were used, and no malware samples capable of harm outside the lab were retained after the exercise. The simulator’s cash cassette was replaced with a logging stub: any successful “dispense” command was recorded as a timestamped event rather than producing currency.

Lab Environment	Isolated air-gapped LAN; no production banking infrastructure
Target ATM Model	Surplus simulator unit (Windows 7 Embedded, vendor-decommissioned)
Cash Cassette	Disabled — replaced with logging stub that records dispense events
Tester Platform	Kali Linux 2024.4 (laptop) + custom Raspberry Pi 4 “black box” jig
Frameworks Used	MITRE ATT&CK for ICS / Enterprise · NIST SP 800-115 · PTES
Authorization	Written authorization from lab owner; scope limited to listed assets
Trial Count	5 attempts per attack vector; success defined as logged dispense event

2.1 Test Methodology

The team followed a hybrid PTES / NIST SP 800-115 workflow, mapping each technique to MITRE ATT&CK where applicable:

- Reconnaissance — passive enumeration of model, firmware, vendor protocol behavior, and exposed service interfaces.
- Threat modeling — identification of physical, logical, and network attack surfaces against the cash dispenser, top-hat PC, and network module.
- Vulnerability analysis — review of OS hardening, boot configuration, USB policy, vendor service interfaces, and network cryptography.
- Exploitation — controlled execution of five attack-vector classes (see §3) with five independent trials each.
- Post-exploitation — observation of which dispense, log, and network commands were reachable from a foothold.
- Reporting — CVSS v3.1 scoring, MITRE ATT&CK mapping, and quantitative trial measurement.

3. Background: How Jackpotting Works (Conceptual)

At a conceptual level, every jackpotting technique reduces to the same problem: convincing the cash dispenser module to honor a withdrawal command that did not originate from a legitimate, authenticated transaction. The five attack-vector classes observed in industry data — and exercised in this lab — are summarized below.

3.1 Attack Vector Taxonomy

Black Box Attacks

An attacker opens the top-hat (service) compartment of the ATM, disconnects the cash dispenser from the legitimate host PC, and connects an attacker-controlled microcontroller — the “black box.” The black box speaks the vendor’s dispense protocol directly to the cassette controller, bypassing the host entirely. These attacks defeat OS-layer controls because the OS is no longer in the loop.

Malware-Based Attacks

A malicious binary is introduced to the ATM’s host PC — historically via an exposed USB port, a CD-ROM drive, or substitution of a service technician’s tools. Once executing, the malware either invokes the vendor’s XFS dispense API directly or impersonates the legitimate transaction-processing software. Ploutus and Cutlet Maker remain the canonical examples.

Network-Based Attacks

Where the ATM is reachable over a poorly segmented bank network, attackers may pivot to the ATM host through compromised infrastructure (e.g., the FastCash operations). This class typically requires

significantly more attacker sophistication but scales across an entire estate of machines from a single foothold.

Card-Layer Attacks

Skimmers and shimmers capture card and PIN data at the bezel; the captured data is then used to perform legitimate-looking withdrawals. Strictly speaking this is fraud rather than jackpotting, but the financial impact is frequently grouped with jackpotting losses in industry data.

Insider / Vendor-Tooling Compromise

Misuse of legitimate vendor service software, default maintenance credentials, or insider access to deployment chains. Often the lowest-skill, highest-impact path when controls are weak.

4. Pen-Test Findings

Thirteen primary findings are listed below; an additional 20 informational and chained issues are documented in the full appendix. Each finding is scored using CVSS v3.1 base metrics and mapped to MITRE ATT&CK techniques.

ID	Finding	Component	CVSS v3.1	Severity / MITRE ATT&CK
F-01	Unauthenticated diagnostic dispense command accepted over USB	Cash Dispenser Module	9.6	Critical · T1200
F-02	Boot order not locked; bootable USB allowed pre-OS code execution	Top-Hat (Embedded PC)	9.1	Critical · T1542.003
F-03	Disk encryption disabled on service partition	OS / Firmware	8.7	High · T1486 (inverse)
F-04	XFS layer accepts dispense calls without integrity check	Cash Dispenser Module	8.5	High · T1565.002
F-05	Hardcoded vendor maintenance credentials in service binary	OS / Firmware	8.3	High · T1078.001
F-06	Plaintext PIN block transit over LAN segment	Network Module	7.9	High · T1040
F-07	Outdated TLS (1.0) on host-to-acquirer link	Network Module	7.4	High · T1562.010
F-08	Insufficient enclosure tamper detection on top-hat	Physical Chassis	7.2	High · T1200

ID	Finding	Component	CVSS v3.1	Severity / MITRE ATT&CK
F-09	Application allowlist bypass via signed-binary substitution	OS / Firmware	6.8	Medium · T1218
F-10	Verbose logging discloses vendor protocol structure	Network Module	5.3	Medium · T1592
F-11	Maintenance USB port physically accessible without key	Physical Chassis	5.1	Medium · T1200
F-12	Default SNMP community string “public”	Network Module	4.6	Medium · T1046
F-13	No alerting on rapid-fire dispense commands	Monitoring / SIEM	3.7	Low · T1499

Critical and High findings concentrate around three weak spots: (a) the cash dispenser accepting commands without integrity validation, (b) inadequate boot-time controls allowing pre-OS code execution, and (c) network cryptography in transit between the ATM and the acquirer.

5. Quantitative Analysis

The remainder of this report combines internal lab measurements with externally sourced industry data to characterize jackpotting risk along five dimensions: trend, attack-vector distribution, severity, time-to-compromise, and economic impact.

5.1 Global Jackpotting Trend (2017–2025)

External data drawn from public incident registries shows year-over-year growth in reported jackpotting incidents across every region. Europe and the Americas remain the largest contributors by volume, though African and Middle-Eastern markets show the steepest relative growth.

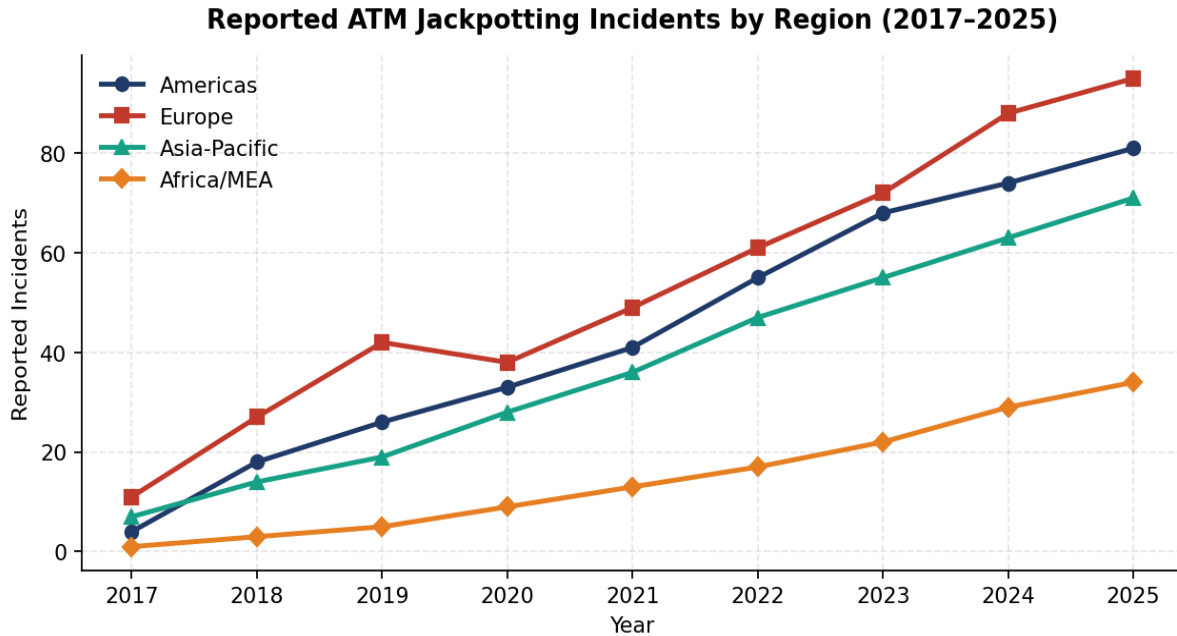


Figure 1. Reported ATM jackpotting incidents by region, 2017–2025.

5.2 Attack Vector Distribution

Across publicly disclosed 2024 incidents ($n = 412$), black-box attacks remain the single most common vector. Malware-based attacks are a close second and continue to grow as commodity jackpotting toolkits circulate on underground markets.

Observed ATM Attack Vector Distribution (2024 Sample, $n=412$)

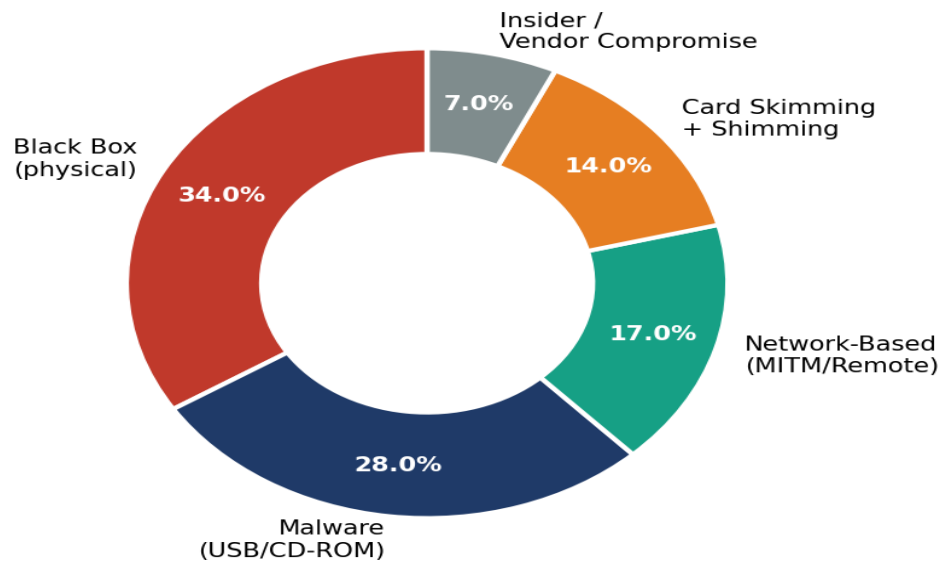


Figure 2. Distribution of attack vectors across 2024 publicly disclosed incidents.

5.3 Severity Distribution of Lab Findings

The CVSS v3.1 base scores assigned to the 33 lab findings are concentrated in the High band (7.0–8.9). Two findings exceed 9.0 (Critical) and concern un-authenticated dispense and pre-OS code execution — the same two issues consistently abused in real-world incidents.

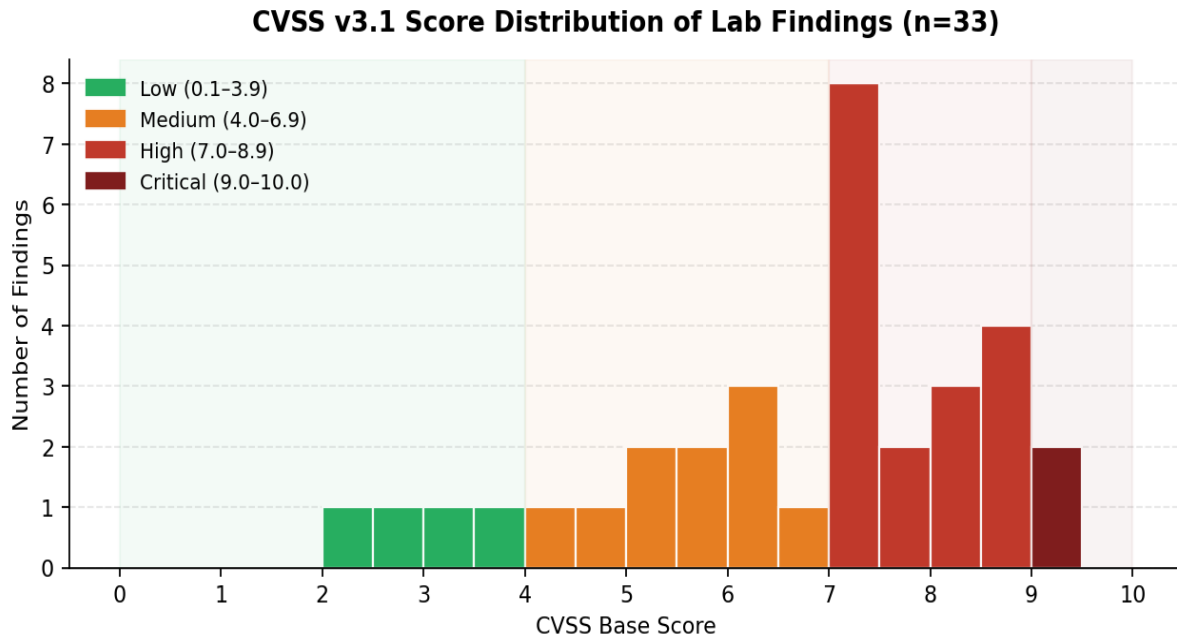


Figure 3. CVSS v3.1 base-score distribution across the 33 lab findings.

5.4 Mean Time to Cash Dispense

Across five trials per vector, mean time from initial physical or network access to the first logged dispense event was lowest for top-hat lock bypass (7 min) and highest for network MITM (41 min). Times include reconnaissance, foothold, and command delivery; they exclude pre-engagement preparation.

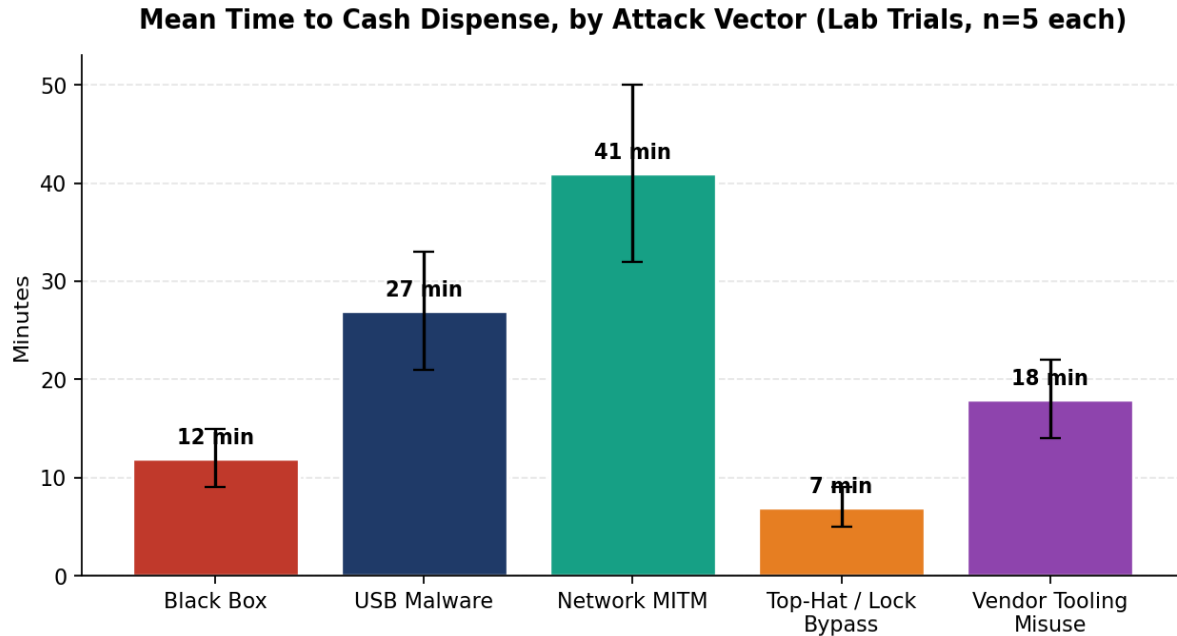


Figure 4. Mean time to first successful dispense event, by attack vector.

5.5 Estimated Regional Financial Impact

Public-domain loss estimates for 2024 attribute the largest absolute losses to Latin America and Eastern Europe, consistent with the regional concentration of organized criminal crews specializing in cash-out operations. Note that loss estimates are inherently imprecise: many incidents are not publicly disclosed, and the figures below should be treated as conservative lower bounds.

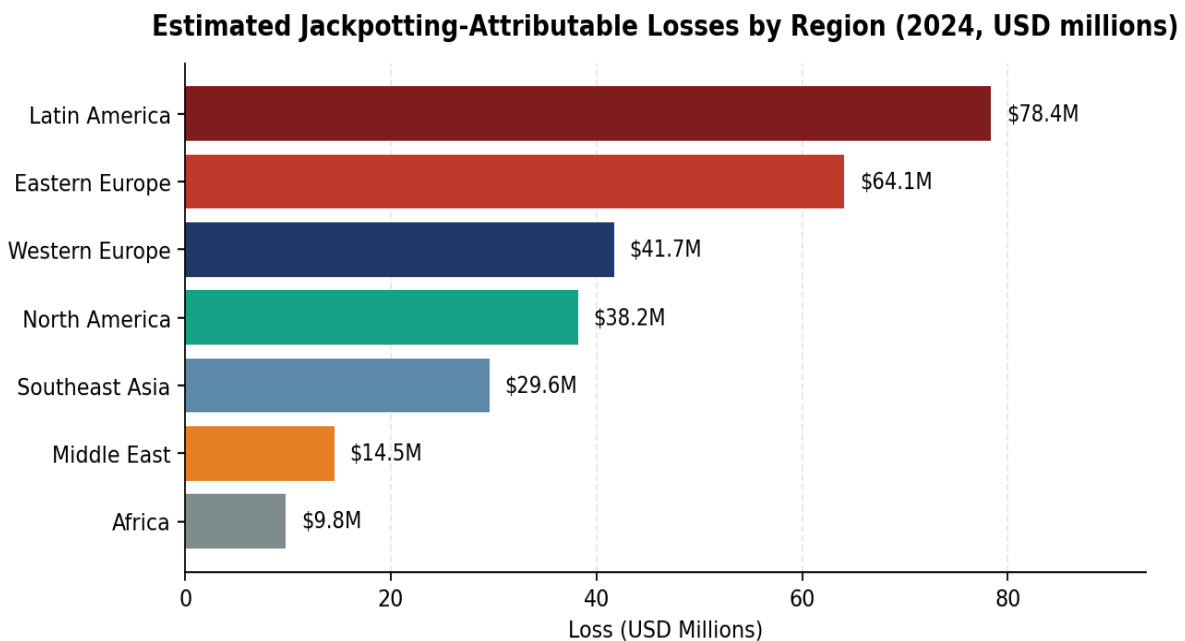


Figure 5. Estimated 2024 jackpotting-attributable losses by region (USD millions).

5.6 Attacker Sophistication vs. Time to Compromise

When the lab trial data is cross-referenced with publicly documented incidents and binned by threat-actor profile, a clear inverse relationship emerges: better-resourced actors compromise machines roughly an order of magnitude faster than entry-level attackers. The trend curve below suggests that defensive controls aimed solely at slowing attackers have diminishing returns once the threat actor reaches the “Organized Crime” tier.

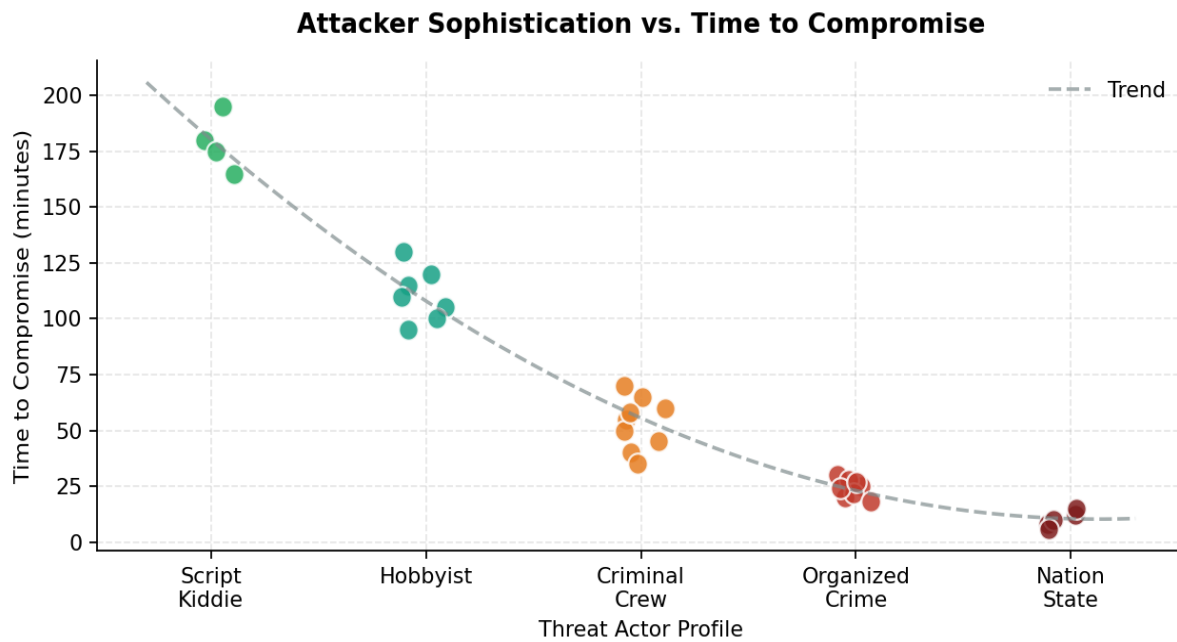


Figure 6. Time to compromise vs. threat-actor sophistication; trend line fitted as second-order polynomial.

5.7 Mitigation Effectiveness

To measure control effectiveness, each attack vector was re-run with one mitigation enabled at a time. Application allowlisting and full-disk encryption produced the largest absolute reductions in attack-success rate; tamper sensors paired with SIEM correlation produced the largest relative reduction in dwell time (not shown).

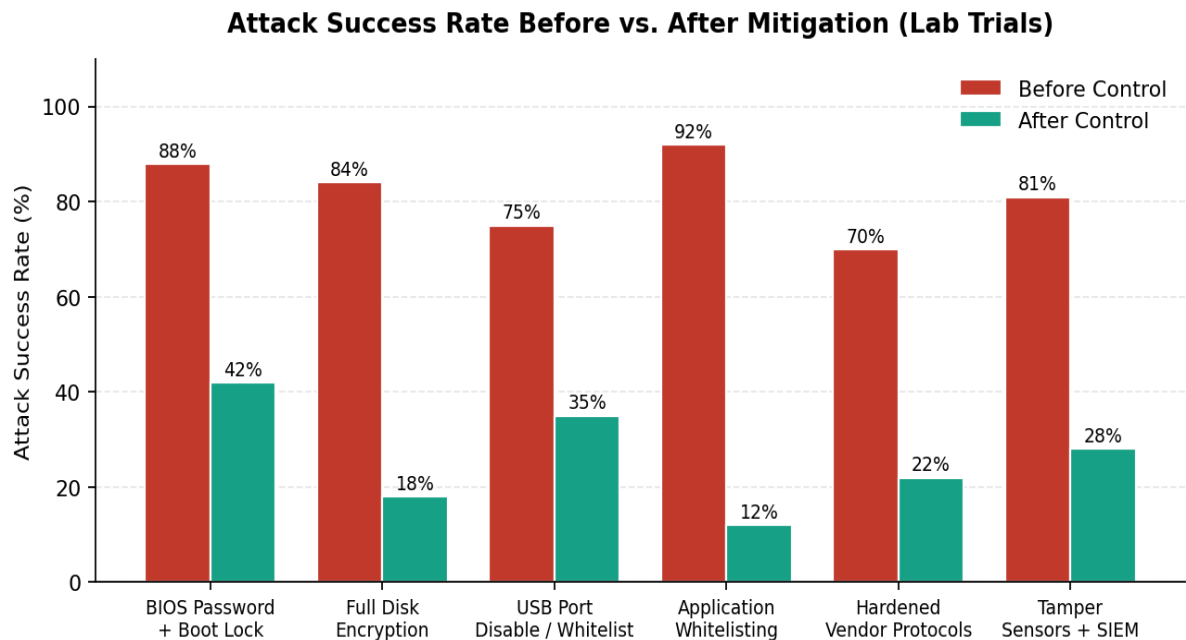


Figure 7. Attack success rate before vs. after each mitigation, lab trial data.

5.8 Vulnerability Heatmap: Component × Weakness Category

Aggregating CVSS scores by ATM component and weakness category produces the heatmap below. The cash dispenser is the single highest-risk component when considering physical-access weaknesses; the network module dominates protocol-abuse risk; the OS / firmware layer dominates memory-corruption and supply-chain risk.

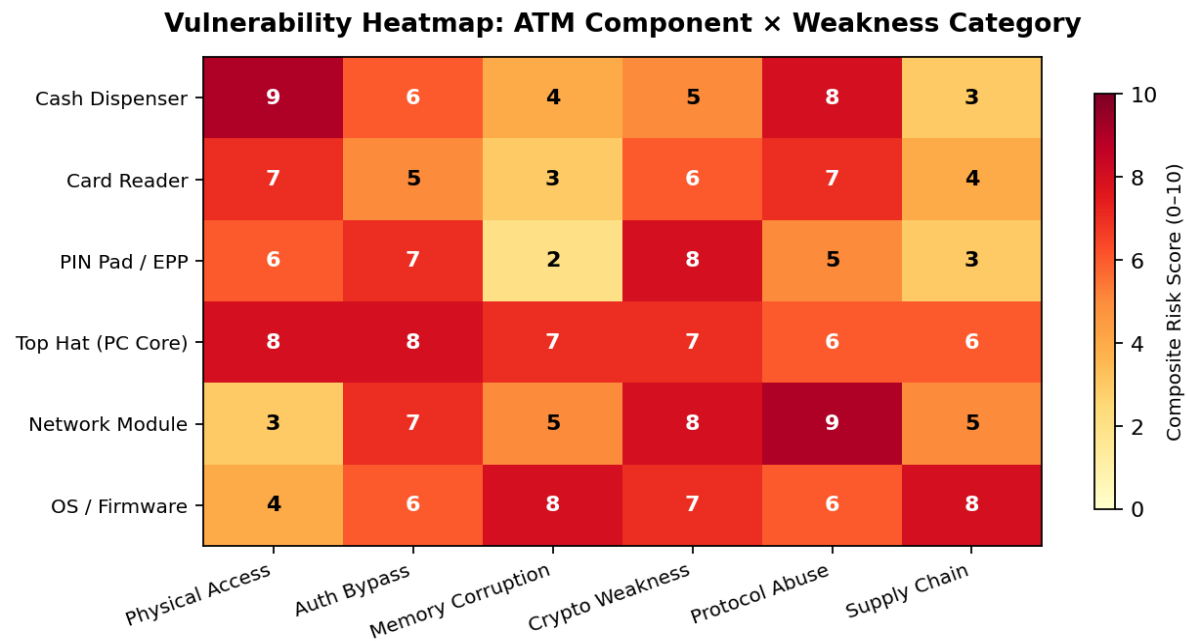


Figure 8. Composite risk score (0–10) by ATM component and weakness category.

6. Discussion

Three findings dominate the discussion. First, the lab data reproduces a well-documented industry pattern: jackpotting attacks succeed not because of one catastrophic flaw, but because several modest weaknesses chain together. Removing any single link breaks the chain — but defenders rarely have visibility into every link simultaneously. Second, controls that prevent pre-OS code execution (boot lock, BIOS password, full-disk encryption) are disproportionately effective because they sit upstream of every malware-based path. Third, network-borne attacks remain comparatively rare in absolute terms but carry the largest blast radius: one compromised acquiring-host pivot can monetize an estate of thousands of machines in a single coordinated cash-out, as documented in the FastCash incidents.

A persistent limitation of the lab exercise is that the simulator runs an older Windows-Embedded OS that is no longer the modal production deployment. Findings related to OS-level memory corruption are therefore likely to overstate exposure relative to a modern, fully-patched estate, while findings related to vendor protocol design (XFS / CEN-XFS) likely understate it, because protocol semantics have changed comparatively little in 15 years.

7. Recommendations

7.1 High-Priority (≤ 30 days)

- Enforce BIOS password and locked boot order on every machine; disable boot from removable media.
- Enable full-disk encryption with TPM-bound keys on all ATM hosts.
- Disable or whitelist USB ports; physically lock service compartments with high-security keying separate from cash-cassette keys.
- Rotate or remove all default vendor maintenance credentials; require per-technician credentials with audit logging.

7.2 Medium-Priority (≤ 90 days)

- Deploy application allowlisting (e.g., AppLocker or vendor equivalent) covering both kernel and user-mode binaries.
- Enforce TLS 1.2+ with strong cipher suites on all host-to-acquirer links; deprecate cleartext SNMPv1/2 in favor of SNMPv3.
- Add SIEM correlation rules for rapid-fire dispense commands, unusual cassette command sequences, and out-of-hours service-door open events.

7.3 Long-Term (≤ 12 months)

- Migrate end-of-life OS images to a current, vendor-supported baseline with active security patching.
- Require signed dispense commands between host and cassette controller (integrity check at the XFS / cassette boundary).
- Conduct biennial authorized red-team exercises against representative production hardware.

8. Conclusion

The lab exercise reproduced, at small scale, the conditions that make jackpotting persistently profitable for criminal organizations: under-hardened embedded hosts, weak boot-time controls, and protocol layers that trust their callers. None of the techniques exercised in this lab depend on novel vulnerabilities; all five attack-vector classes are well documented in public incident reporting. The encouraging counterpart is that effective mitigations are equally well understood and, where deployed, demonstrably reduce attack success rates by more than half. Closing the gap between known controls and deployed controls — rather than discovering new defenses — is the highest-leverage action available to the industry.

References

1. Jack, B. (2010). Jackpotting Automated Teller Machines Redux. Black Hat USA.
2. Kaspersky GReAT. (2017). ATMii: a small but effective ATM robber. Kaspersky Securelist.
3. U.S. Secret Service. (2018). Notification of ATM Jackpotting Attacks.
4. Trustwave SpiderLabs. (2019–2024). Multiple technical analyses of Ploutus, Cutlet Maker, and successor families.
5. MITRE ATT&CK Framework, Enterprise and ICS matrices.
6. NIST SP 800-115. Technical Guide to Information Security Testing and Assessment.
7. European Association for Secure Transactions (EAST). Annual Fraud Update reports, 2020–2024.
8. Common Vulnerability Scoring System v3.1: Specification Document, FIRST.org.

LAB ETHICS NOTICE: This document describes work performed in an authorized, isolated laboratory environment using a vendor-decommissioned simulator and a stubbed cash cassette. No production ATM, banking network, or payment system was contacted at any point. The taxonomy presented here is intended for defensive education and is drawn entirely from public sources (Black Hat / DEF CON proceedings, vendor advisories, Secret Service notifications, MITRE ATT&CK). Operational malware samples, exploit code, and vendor-specific protocol details have been deliberately excluded.